

Internal Cybersecurity Audit: Botium Toys

Date: April 29, 2026

Auditor: Cody Marshall

Risk Score: 8/10 (High)

1. Scope & Goals

Scope:

The scope of this audit is defined as the entire security program at Botium Toys. This includes a comprehensive assessment of all physical and digital assets, internal security processes, and current procedures related to the implementation of controls. The audit covers on-premises equipment, employee devices (desktops, laptops, and mobile), storefront inventory systems, and legacy maintenance protocols.

Goals:

The primary objective is to evaluate the existing security posture of Botium Toys and complete a formal controls and compliance checklist. This assessment will identify critical gaps in security best practices and provide a roadmap for implementing the necessary technical and administrative controls to mitigate risk and ensure adherence to international regulations.

2. Inventory of Assets

The following assets are managed by the IT Department and fall within the audit perimeter:

- **On-premises Infrastructure:** Office equipment, internal network hardware, and internet access systems.
- **Employee End-user Devices:** Desktops, laptops, smartphones, and remote workstation accessories (headsets, docking stations).
- **Retail & Inventory:** Storefront products (on-site/online) and warehouse management systems.
- **Systems & Software:** Accounting, telecommunications, database management, and e-commerce platforms.

- **Critical Infrastructure:** Surveillance cameras (CCTV), physical locks, and fire detection/prevention systems.
- **Legacy Systems:** End-of-life systems requiring specialized manual monitoring.

3. Risk Assessment

Risk Description:

Currently, there is inadequate management of assets and a critical lack of technical controls. Botium Toys is not fully compliant with U.S. and international regulations, leading to a high risk of data breach, financial penalties, and loss of business continuity.

Risk Score: 8 / 10 (High)

Potential Impact:

- **Asset Loss (Medium):** Lack of a formal classification system means the IT department cannot effectively prioritize asset protection during an incident.
- **Compliance/Legal (High):** Failure to adhere to PCI DSS and GDPR best practices exposes the company to massive fines and legal action.
- **Operational (High):** The absence of disaster recovery plans and backups creates a “single point of failure” for the entire business.

4. Controls Assessment Checklist

Control	In Place	Explanation
Least Privilege	No	All employees currently have access to sensitive customer data, increasing breach risk.
Disaster Recovery	No	No formal plans exist, posing a critical threat to business continuity.
Password Policies	Yes	Policies are in place but are nominal and lack modern complexity requirements.
Separation of Duties	No	CEO currently manages both day-to-day operations and payroll, creating a fraud risk.
Firewall	Yes	Properly configured to block traffic based on defined security rules.

Intrusion Detection (IDS)	No	No system is in place to identify or alert on potential unauthorized entries.
Backups	No	Lack of data backups prevents recovery in the event of a ransomware or hardware failure.
Antivirus Software	Yes	Installed and monitored regularly by the IT department.
Legacy Monitoring	Yes	Manual monitoring is performed, but lacks a formal schedule or intervention policy.
Encryption	No	Sensitive financial and PII data is stored/transmitted in plaintext.
Password Management	No	No centralized system exists to enforce password complexity or security.
Physical Security	Yes	CCTV, physical locks, and fire prevention systems are all functioning and up to date.

5. Compliance Checklist

Payment Card Industry Data Security Standard (PCI DSS)

Best Practice	Adherence	Explanation
Authorized Access Only	No	All employees currently have access to credit card information.
Secure Data Storage	No	Cardholder data is stored in a non-secure, non-encrypted environment.
Encryption Procedures	No	No encryption is used at transaction touchpoints or for data-at-rest.
Secure Password Policies	No	Current policies are nominal and not enforced by a management system.

General Data Protection Regulation (GDPR)

Best Practice	Adherence	Explanation
---------------	-----------	-------------

Data Privacy/Security	No	Lack of encryption and access controls fails to protect E.U. citizens' data.
72-Hour Notification	Yes	A formal plan is in place to notify customers within 72 hours of a breach.
Data Classification	No	Assets are listed but not formally classified by sensitivity level.
Privacy Policy Enforcement	Yes	Privacy procedures are developed and enforced among internal staff.

6. Recommendations

To reduce the current Risk Score from an **8** to a manageable level, the following remediations should be prioritized:

1. **Implement Identity & Access Management (IAM):** Enforce the Principle of Least Privilege and Separation of Duties to ensure only authorized personnel can access sensitive PII and financial data.
2. **Deploy Data Encryption:** Implement AES-256 encryption for all data-at-rest and TLS for data-in-transit to satisfy PCI DSS and GDPR requirements.
3. **Establish a Disaster Recovery Plan:** Create an automated, off-site backup schedule and a formal recovery procedure to ensure business continuity.
4. **Network Monitoring:** Install an Intrusion Detection System (IDS) to move the security posture from a reactive to a proactive state.
5. **Centralized Password Management:** Deploy a system that enforces modern complexity requirements (special characters, minimum lengths) to mitigate credential-based attacks.

End of Audit Report